

Brilliance EMS

Manager · Employee · HR API Documentation

Base URL: `http://localhost:5000`

Prefixes: `/api/manager` · `/api/employee` · `/api/hr` · `/api/auth`

All protected routes need:

Authorization: Bearer <jwt_token>

Response: { success, message, data }

Error: { success: false, message, errors? }

Roles: candidate | employee | manager | hr | admin

Domain rules:

- Employee can have multiple managers (primary | secondary)
- At most ONE primary manager per employee
- Manager permissions (HR-controlled): teamManagement, approvals, performance, tasks, reports, communication
- Leave / overtime / expense always include reviewing managerId
- Tasks store managerId + assigneeId

0. Auth (shared)

POST /api/auth/login

Auth: No auth

Headers: Content-Type: application/json

Body (JSON):

```
{
  "email": "user@example.com",
  "password": "secret12",
  "role": "manager" // employee | manager | hr | admin | candidate
}
```

Note: Returns data.token + data.user

GET /api/auth/me

Auth: Bearer JWT required

Roles: any authenticated

Headers: Authorization: Bearer <token>

Note: Employee !' managers[] + profileCompletion. Manager !' permissions + managerProfile + profileCompletion.

1. Manager APIs — /api/manager

Role: manager. Most routes also need a ManagerProfile permission flag.

GET /api/manager/dashboard

Auth: Bearer JWT required

Roles: manager

Headers: Authorization: Bearer <token>

Note: teamSize, presentToday, pendingApprovals, openTasks, profileCompletion, permissions

GET /api/manager/team

Auth: Bearer JWT required

Roles: manager

Headers: Authorization: Bearer <token>

POST /api/manager/team

Auth: Bearer JWT required

Roles: manager

Permission: teamManagement

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "employeeId": "<User ObjectId>",
  "relationshipType": "primary" // optional: primary | secondary (default secondary)
}
```

DELETE /api/manager/team/:employeeId

Auth: Bearer JWT required

Roles: manager

Permission: teamManagement

Headers: Authorization: Bearer <token>

GET /api/manager/employees/available

Auth: Bearer JWT required

Roles: manager

Permission: teamManagement

Headers: Authorization: Bearer <token>

Note: Employees not yet on MY team (may still have other managers)

GET /api/manager/tasks

Auth: Bearer JWT required

Roles: manager

Permission: tasks

Headers: Authorization: Bearer <token>

Query: status?=pending|in_progress|completed

POST /api/manager/tasks

Auth: Bearer JWT required

Roles: manager

Permission: tasks

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "title": "Ship feature X",
  "description": "Optional details",
  "assigneeId": "<employee UserId>",
  "deadline": "2026-08-20T17:00:00.000Z",
  "priority": "high"    // high | medium | low
}
```

PATCH /api/manager/tasks/:id

Auth: Bearer JWT required

Roles: manager

Permission: tasks

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "title": "...",
  "status": "in_progress",
  "priority": "medium",
  "deadline": "...",
  "assigneeId": "..."
}
```

DELETE /api/manager/tasks/:id

Auth: Bearer JWT required

Roles: manager

Permission: tasks

Headers: Authorization: Bearer <token>

Note: Soft-delete

GET /api/manager/approvals

Auth: Bearer JWT required

Roles: manager

Permission: approvals

Headers: Authorization: Bearer <token>

Query: type?=leave|overtime|expense & status?=pending|approved|rejected

PATCH /api/manager/approvals/:type/:id

Auth: Bearer JWT required

Roles: manager

Permission: approvals

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "status": "approved",    // approved | rejected
  "note": "Looks good"    // optional
}
```

Note: type path param = leave | overtime | expense

GET /api/manager/reviews

Auth: Bearer JWT required

Roles: manager

Permission: performance

Headers: Authorization: Bearer <token>

POST /api/manager/reviews

Auth: Bearer JWT required

Roles: manager

Permission: performance

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "employeeId": "<UserId>",
  "period": "2026-Q2",
  "rating": 4,
  "feedback": "Strong delivery",
  "kpis": [
    { "name": "Delivery", "target": "90%", "actual": "95%" }
  ]
}
```

GET /api/manager/reviews/:id/appraisal

Auth: Bearer JWT required

Roles: manager

Permission: performance

Headers: Authorization: Bearer <token>

Note: Appraisal payload (PDF later)

POST /api/manager/announcements

Auth: Bearer JWT required

Roles: manager

Permission: communication

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "title": "Sprint kickoff",
  "body": "Standup at 10 AM"
}
```

Note: audience=team; notifies current team members

GET /api/manager/announcements

Auth: Bearer JWT required

Roles: manager

Permission: communication

Headers: Authorization: Bearer <token>

POST /api/manager/messages

Auth: Bearer JWT required

Roles: manager

Permission: communication

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "toEmployeeId": "<UserId>",
  "title": "Optional",
  "body": "Please update the task status"
}
```

GET /api/manager/reports/overview

Auth: Bearer JWT required

Roles: manager

Permission: reports

Headers: Authorization: Bearer <token>

GET /api/manager/reports/attendance

Auth: Bearer JWT required

Roles: manager

Permission: reports

Headers: Authorization: Bearer <token>

Note: Mockable aggregate for now

GET /api/manager/reports/productivity

Auth: Bearer JWT required
Roles: manager
Permission: reports
Headers: Authorization: Bearer <token>

GET /api/manager/reports/performance

Auth: Bearer JWT required
Roles: manager
Permission: reports
Headers: Authorization: Bearer <token>

2. Employee APIs — /api/employee

Role: employee. Requests must target an assigned managerId.

GET /api/employee/dashboard

Auth: Bearer JWT required
Roles: employee
Headers: Authorization: Bearer <token>
Note: managers, pendingTasks, announcements, alerts, profileCompletion

GET /api/employee/managers

Auth: Bearer JWT required
Roles: employee
Headers: Authorization: Bearer <token>
Note: [{ id, name, relationshipType, department, ... }]

GET /api/employee/tasks

Auth: Bearer JWT required
Roles: employee
Headers: Authorization: Bearer <token>
Query: managerId? & status?=pending|in_progress|completed

PATCH /api/employee/tasks/:id/status

Auth: Bearer JWT required
Roles: employee
Headers: Content-Type: application/json | Authorization: Bearer <token>
Body (JSON):
{
 "status": "in_progress" // pending | in_progress | completed
}
Note: Own tasks only

POST /api/employee/leave

Auth: Bearer JWT required
Roles: employee
Headers: Content-Type: application/json | Authorization: Bearer <token>
Body (JSON):
{
 "managerId": "<assigned manager UserId>",
 "type": "annual", // annual | sick | casual | unpaid | ...
 "from": "2026-08-10",
 "to": "2026-08-12",
 "reason": "Family event",
 "days": 3 // optional; auto-calculated if omitted
}

GET /api/employee/leave

Auth: Bearer JWT required
Roles: employee
Headers: Authorization: Bearer <token>
Query: managerId? & status?

POST /api/employee/overtime

Auth: Bearer JWT required
Roles: employee
Headers: Content-Type: application/json | Authorization: Bearer <token>
Body (JSON):
{
 "managerId": "<UserId>",
 "date": "2026-08-05",
 "hours": 2.5,
 "reason": "Release support"
}

GET /api/employee/overtime

Auth: Bearer JWT required

Roles: employee

Headers: Authorization: Bearer <token>

Query: managerId? & status?

POST /api/employee/expenses

Auth: Bearer JWT required

Roles: employee

Headers: Content-Type: multipart/form-data | Authorization: Bearer <token>

Body (multipart/form-data):

managerId = <UserId> (required)
category = travel|meal|equipment|training|other
title = Taxi to client
amount = 2500
date = 2026-08-01
description = optional
receipt = file (image/pdf)

GET /api/employee/expenses

Auth: Bearer JWT required

Roles: employee

Headers: Authorization: Bearer <token>

Query: managerId? & status?

GET /api/employee/profile-completion

Auth: Bearer JWT required

Roles: employee

Headers: Authorization: Bearer <token>

Note: Returns incomplete: [{ key, title, screen }] for personalInfo, documents, emergencyContact, bankDetails

PATCH /api/employee/profile-completion/:section

Auth: Bearer JWT required

Roles: employee

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

// section = personalInfo | documents | emergencyContact | bankDetails

// personalInfo

{ "name": "...", "phone": "...", "address": { "street", "city", "country" } }

// emergencyContact

{ "name": "...", "relation": "Brother", "phone": "..." }

// or { "emergencyContacts": [{ name, relation, phone }] }

// bankDetails

{ "accountTitle": "...", "bankName": "...", "accountNumber": "...", "iban": "..." }

// documents

{ "documents": [{ "name": "CNIC", "url": "..." }] }

3. HR APIs — /api/hr

Roles: hr | admin

GET /api/hr/dashboard

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

GET /api/hr/profile-alerts

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

Note: Employees/managers with incomplete profile sections

GET /api/hr/managers

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

Query: status?=active|inactive & search?

POST /api/hr/managers

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "name": "Sara Manager",
  "email": "sara.mgr@brilliance.local",
  "password": "Secret12",
  "title": "Engineering Manager",
  "department": "Engineering",
  "phone": "0300...",
  "team": [
    { "employeeId": "<UserId>", "relationshipType": "primary" }
  ],
  "permissions": {
    "teamManagement": true,
    "approvals": true,
    "performance": true,
    "tasks": true,
    "reports": true,
    "communication": true
  }
}
```

GET /api/hr/managers/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

Note: id = ManagerProfile_id OR User_id

PATCH /api/hr/managers/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "title": "...",
  "department": "...",
  "status": "active",
  "name": "...",
  "phone": "...",
  "permissions": { "reports": false },
  "team": [ { "employeeId": "...", "relationshipType": "secondary" } ]
}
```

POST /api/hr/managers/:id/transfer

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "department": "Product",
  "title": "Product Manager" // optional
}
```

POST /api/hr/managers/:id/deactivate

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "reassignToManagerId": "<UserId>" // optional – moves team assignments
}
```

GET /api/hr/managers/:id/activity

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

GET /api/hr/managers/:id/report

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

GET /api/hr/managers/:id/permissions

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

PUT /api/hr/managers/:id/permissions

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "teamManagement": true,
  "approvals": true,
  "performance": true,
  "tasks": true,
  "reports": false,
  "communication": true
}
```

POST /api/hr/assignments

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "managerId": "<UserId>",
  "employeeId": "<UserId>",
  "relationshipType": "primary" // primary | secondary
}
```

PATCH /api/hr/assignments/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "relationshipType": "secondary" }
```

DELETE /api/hr/assignments/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

GET /api/hr/employees/:id/managers

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

4. Quick curl examples

```
# Login as HR
curl -X POST http://localhost:5000/api/auth/login \
  -H "Content-Type: application/json" \
  -d '{"email":"hr@x.com","password":"...","role":"hr"}'

# Create manager
curl -X POST http://localhost:5000/api/hr/managers \
  -H "Authorization: Bearer $HR_TOKEN" -H "Content-Type: application/json" \
  -d '{"name":"Mgr","email":"m@x.com","password":"Secret12","title":"EM"}'

# Assign primary manager
curl -X POST http://localhost:5000/api/hr/assignments \
  -H "Authorization: Bearer $HR_TOKEN" -H "Content-Type: application/json" \
  -d '{"managerId":"...","employeeId":"...","relationshipType":"primary"}'

# Employee leave
curl -X POST http://localhost:5000/api/employee/leave \
  -H "Authorization: Bearer $EMP_TOKEN" -H "Content-Type: application/json" \
  -d '{"managerId":"...","type":"annual","from":"2026-08-10","to":"2026-08-12","reason":"Trip"}'

# Manager approve
curl -X PATCH http://localhost:5000/api/manager/approvals/leave/LEAVE_ID \
  -H "Authorization: Bearer $MGR_TOKEN" -H "Content-Type: application/json" \
  -d '{"status":"approved","note":"OK"}'
```

Generated for Brilliance EMS FYP — Manager / Employee / HR module. Existing /api/leaves & /api/expenses remain available as legacy domain routes.